

Digital Customer

Customer Portal Modernisation

Solution Architecture Document

SAD-CPM-2026-014 V-0.9

Effective Date: 22/06/2026

SENSITIVITY CLASSIFICATION: Internal Use

Table of Contents

Revision History	3
1. Solution Overview	3
2. Architecture	3
2.1 Component Structure	3
2.2 API Design	3
2.3 Session Handling	3
2.4 Architecture Decisions	3
3. Data Design	4
3.1 Source of Truth	4
3.2 Physical Model	4
3.3 Formats	4
4. Security	4
4.1 Authentication	4
4.2 Authorisation	4
4.3 Transport and Storage Encryption	4
4.4 Application Security Testing	5
5. Integration	5
5.1 Patterns	5
5.2 Failure Handling	5
6. Deployment and Operations	5
6.1 Packaging	5
6.2 Observability	5
6.3 Availability	5
7. Open Items	6

Revision History

Version	Date	Changed By	Description
0.5	2026-05-11	A. Berger	First draft for internal review
0.9	2026-06-22	A. Berger	Updated after security walkthrough

1. Solution Overview

The Customer Portal Modernisation programme replaces the existing self-service portal with a component-based web application backed by a set of domain services. The portal serves approximately 1.4 million residential and small-business customers, providing account management, billing history, payment, outage reporting and meter reading submission.

The existing portal is a monolithic application with business logic embedded in the presentation layer and direct queries against the billing database. This design replaces it with a React front end consuming published APIs, and a service layer that owns its own data store.

2. Architecture

2.1 Component Structure

The solution comprises a React single-page application, an API gateway, four domain services (Account, Billing View, Outage, Metering) and a read-optimised projection store. The front end contains presentation logic only and consumes back-end capability exclusively through published APIs; no business rules are implemented in the browser.

2.2 API Design

All service interfaces are designed contract-first. The OpenAPI 3.1 specification for each service is authored and reviewed before implementation begins, published to the enterprise API gateway, and registered in the API catalogue. Breaking changes require a new major version; minor versions remain backward compatible for existing consumers.

2.3 Session Handling

Following load testing, session state is held in the application's in-process memory rather than an external cache. This removes a network hop from every authenticated request and reduced p95 latency by 40ms in the prototype. Sticky sessions are configured at the load balancer so that a customer returns to the instance holding their session, and instances are drained rather than terminated during deployment.

2.4 Architecture Decisions

Significant decisions are recorded as Architecture Decision Records in the solution repository, alongside the source code. Each records the context, the decision, the alternatives considered and the consequences, and carries a status of proposed, accepted or superseded. Fourteen ADRs have been

accepted to date.

3. Data Design

3.1 Source of Truth

Customer master data remains owned by the CRM, and account balances by the billing engine. The portal holds no master data of its own. Both are consumed through the enterprise integration platform; the portal maintains a read-only projection for query performance, clearly labelled as a derived copy and rebuilt nightly.

3.2 Physical Model

The projection store is PostgreSQL. The physical model follows the team's established convention, carried over from the existing portal to minimise migration effort:

Object Type	Convention	Example
Table	PascalCase, plural noun	CustomerOrders
Column	camelCase	orderDate
Primary Key	Id	Id
Foreign Key	<Entity>Id	CustomerId
Index	IX_<Table>_<Column>	IX_CustomerOrders_OrderDate

3.3 Formats

All timestamps are stored and exchanged in ISO 8601 with an explicit UTC offset. Monetary amounts carry an ISO 4217 currency code and are stored to four decimal places. All text is UTF-8 end to end.

4. Security

4.1 Authentication

Customers authenticate against the customer identity provider using OpenID Connect. All administrative access to the portal, its infrastructure and its data stores requires multi-factor authentication through the corporate identity provider. Administrative sessions time out after 15 minutes of inactivity. There are no shared or generic accounts in the solution.

4.2 Authorisation

Authorisation uses role-based access control. Four roles are defined · Customer, Contact Centre Agent, Portal Administrator and Read-Only Auditor · and permissions are attached to roles rather than to individuals. Role assignment is requested through the standard access request workflow and approved by the service owner.

4.3 Transport and Storage Encryption

All external traffic terminates TLS 1.3 at the gateway. Service-to-service traffic inside the cluster uses

mutual TLS. TLS 1.0 and 1.1, and all cipher suites below the approved baseline, are explicitly disabled at the gateway. Data at rest in the projection store is encrypted using the platform's managed encryption. Encryption keys are held in the cloud key management service, separate from the data, and rotated annually. No key material appears in source control or configuration.

4.4 Application Security Testing

Static analysis and dependency scanning run on every pull request and block the merge on any high or critical finding. A threat model was produced during design and is reviewed each quarter. Input validation is applied at the API boundary against the OpenAPI schema, and output encoding is applied in the front end. Rate limiting is enforced at the gateway at 120 requests per minute per customer.

5. Integration

5.1 Patterns

The portal integrates with the CRM and the billing engine through the enterprise integration platform using synchronous REST for query operations. Outage reports are published as events to the enterprise event backbone for the outage management system to consume. There are no direct database connections from the portal to any system of record.

5.2 Failure Handling

Outbound calls to the integration platform are wrapped in a circuit breaker with a two-second timeout. Failed calls are retried three times with exponential backoff. Where the billing engine is unavailable, the portal serves the last known balance from the projection with a staleness indicator shown to the customer.

6. Deployment and Operations

6.1 Packaging

Each service is packaged as an OCI container image built from the approved corporate base image. Images are scanned in the build pipeline and rejected on any high or critical vulnerability. Images are immutable and promoted unchanged between environments; all configuration is injected at runtime from the platform's configuration and secret stores.

6.2 Observability

All services emit structured JSON logs. A correlation identifier is generated at the gateway and propagated across every downstream call using the W3C traceparent header, so a single customer interaction can be followed end to end. Business and technical metrics are exposed in Prometheus format and dashboarded in Grafana. Distributed traces are collected via OpenTelemetry. Customer identifiers are masked in all log output.

6.3 Availability

The solution is deployed across three availability zones behind a regional load balancer, with no single points of failure in the request path. The target availability is 99.9%, agreed with the service owner.

7. Open Items

- Confirm the retention period for portal audit logs with the records team
- Agree the approach for customer data subject access requests
- Complete performance testing at projected peak (winter outage scenario)